

Emergent Phenom... · [Follow publication](#)

Securing web applications using Burp Suite and OWASP Juice Shop

A tutorial on testing, securing and learning about web security using BurpSuite and OWASP Juice Shop

Sent as a Newsletter · 6 min read · Nov 8, 2021



Skanda Vivek

Follow

Listen

Share

You might have heard of a recent controversy wherein a “hacker” obtained access to the Social Security Numbers of a few individuals in the Missouri state government.

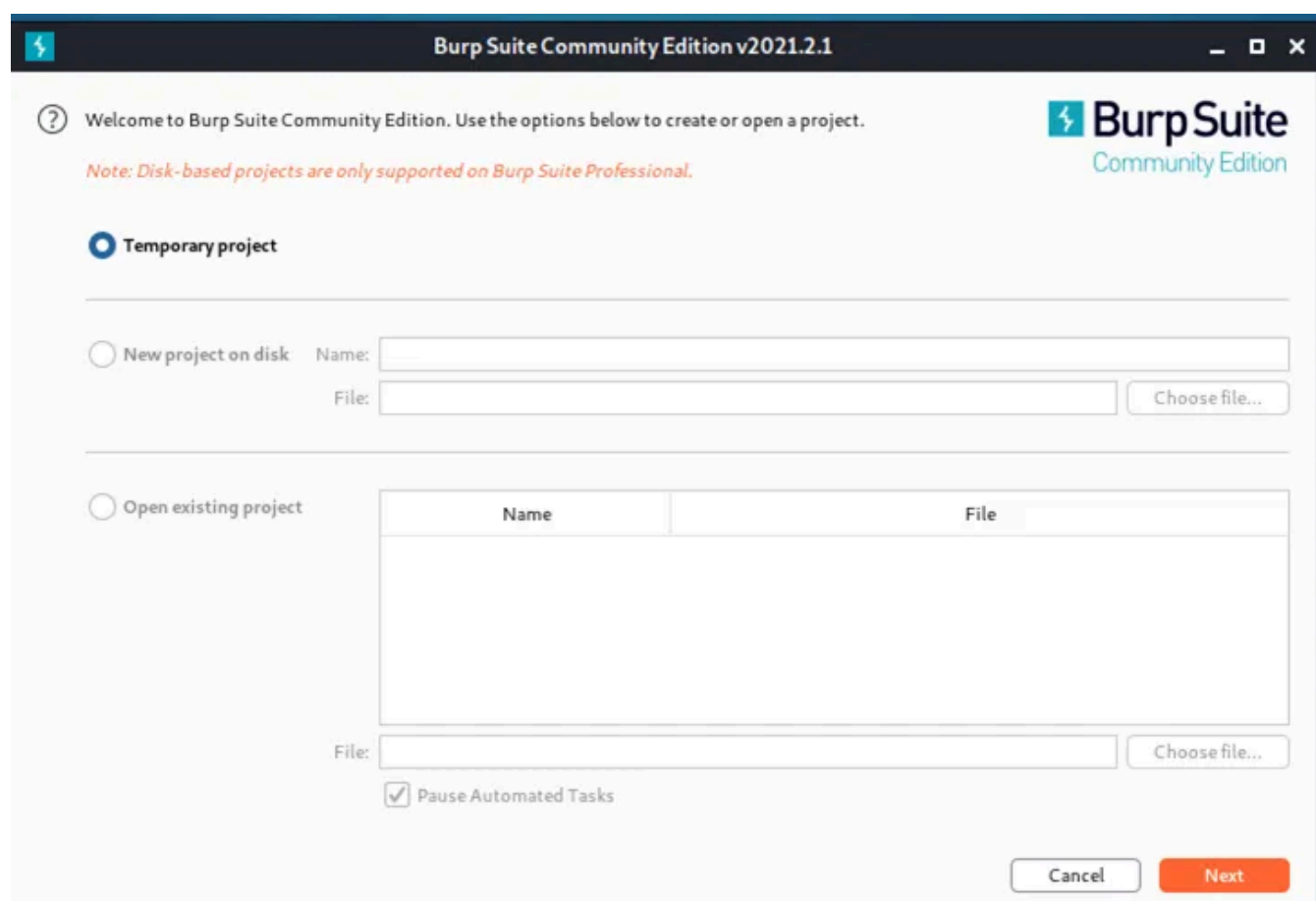


https://twitter.com/GovParsonMO/status/144869776831132160?ref_src=twsrc%5Etfw%7Ctwcamp%5Etweetembed%7Ctwterm%5E144869776831132160%7Ctwgr%5E%7Ctwcon%5Es1&ref_url=https%3A%2F%2Fthreatpost.com%2Fmissouri-prosecute-hacker-data-leak%2F175501%2F

However, it turns out this “hacker” was a reporter, who simply viewed HTML code on a web page. And the SSNs were clearly visible within the HTML code. No — the numbers were not encrypted!

In general, it is extremely important to secure web apps. Insecure web apps could lead to stolen credentials. Or act as a gateway to the rest of an organization’s network leading to severe data breaches, and loss of public trust in the long run. Burp Suite is the go to tool for web app testing. Burp Suite is installed by default on Kali Linux (just like most other cybersecurity tools — Kali Linux is a real game changer!).

You can start off by opening a Temporary project on Burp Suite.



Burp Suite has multiple key features. I’m going to focus on **Proxy**, **Target**, **Repeater**, and **Intruder** for this tutorial.

Proxy: Funnels traffic to Burp Suite

Target: As the name implies — identify the target web app

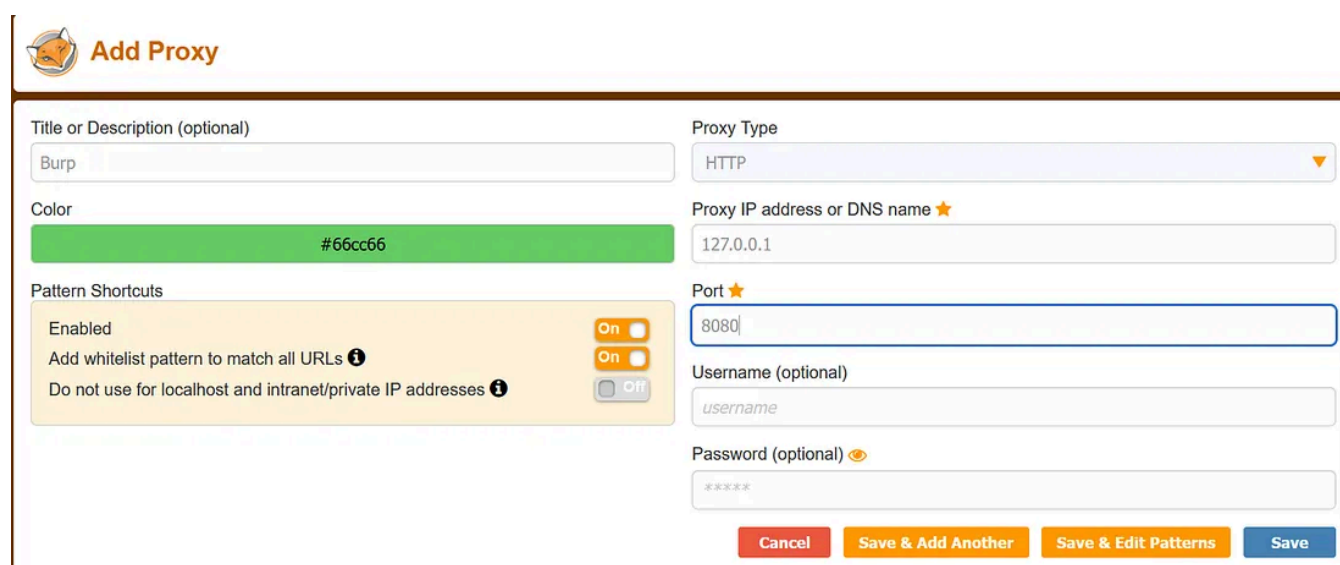
Repeater: Send repeated requests or modification of previously sent requests

Intruder: Mounting attacks on insecure web app authentication fields

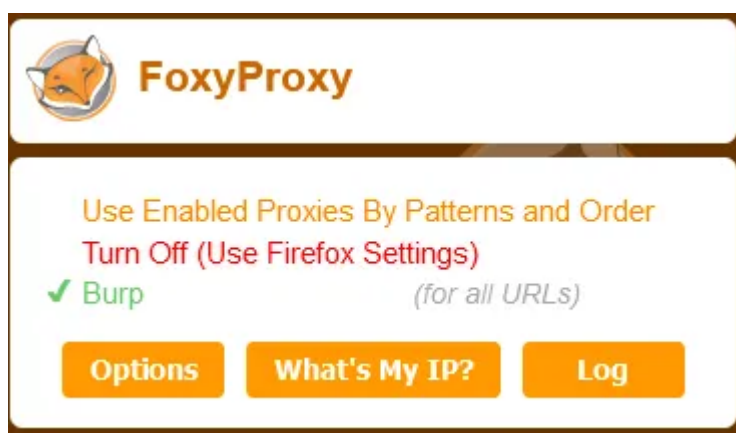
OK — let's get started!

Proxy

In order for Burp Suite to act as a proxy, you need to set up your browser to easily route traffic to and from it. For this, you can install a Firefox web browser extension — 'FoxyProxy Standard.' Modify FoxyProxy to add the Burp Suite proxy. By default, the location of the Burp Proxy server is 127.0.0.1. Add this to FoxyProxy, and turn it on as below.



The image shows the 'Add Proxy' dialog in FoxyProxy. It has a title bar with the FoxyProxy logo and the text 'Add Proxy'. The dialog is divided into two main sections. The left section contains a 'Title or Description (optional)' field with 'Burp' entered, a 'Color' field with a green bar and '#66cc66' text, and a 'Pattern Shortcuts' section with three items: 'Enabled' (On), 'Add whitelist pattern to match all URLs' (On), and 'Do not use for localhost and intranet/private IP addresses' (Off). The right section contains a 'Proxy Type' dropdown set to 'HTTP', a 'Proxy IP address or DNS name' field with '127.0.0.1', a 'Port' field with '8080', a 'Username (optional)' field with 'username', and a 'Password (optional)' field with '*****'. At the bottom are four buttons: 'Cancel', 'Save & Add Another', 'Save & Edit Patterns', and 'Save'.



OWASP Juice Shop

OWASP stands for Open Web Application Security Project and they provide a bunch of open-source software project resources. Burp Suite in combination with OWASP

Medium

Search



Get SKANDA VIVEK'S stories in your inbox

Join Medium for free to get updates from this writer.

Enter your email

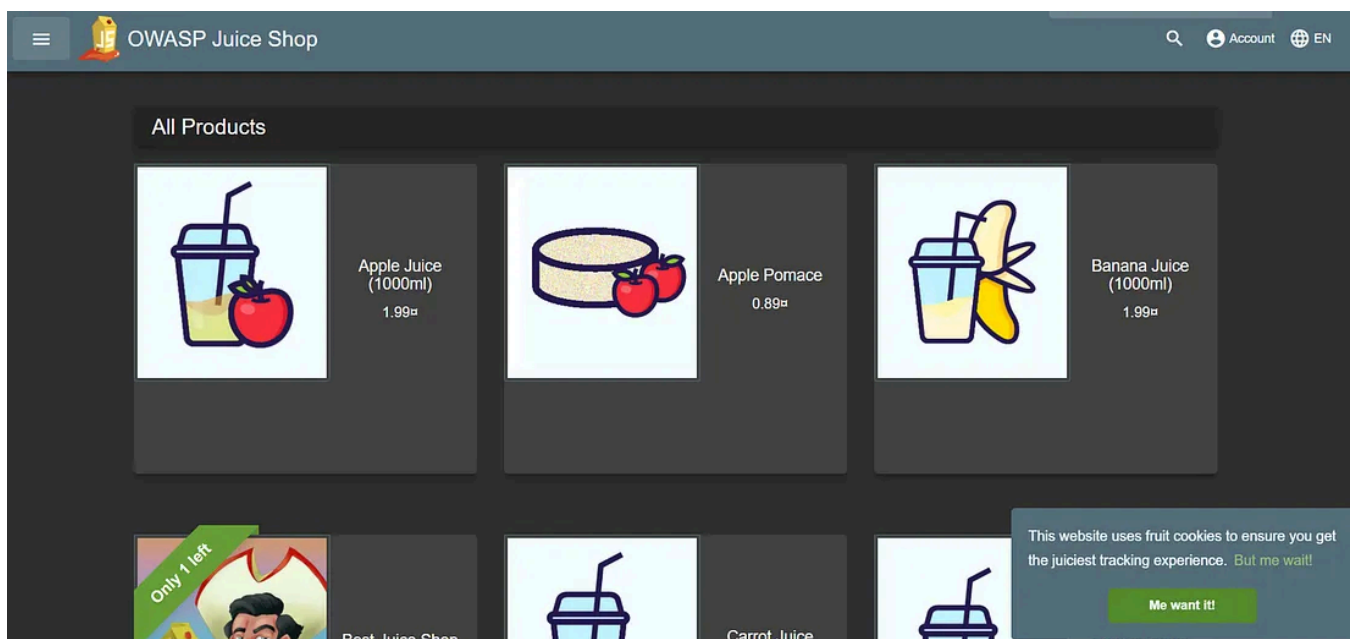
Subscribe

☐ Remember me for faster sign in

OWASP has a quirky but awesome website called the OWASP Juice Shop (I'm always craving for a good juice shop — I never found one in the US, and there are tons in India :)). On the OWASP website, they say:

"OWASP Juice Shop is probably the most modern and sophisticated insecure web application!"

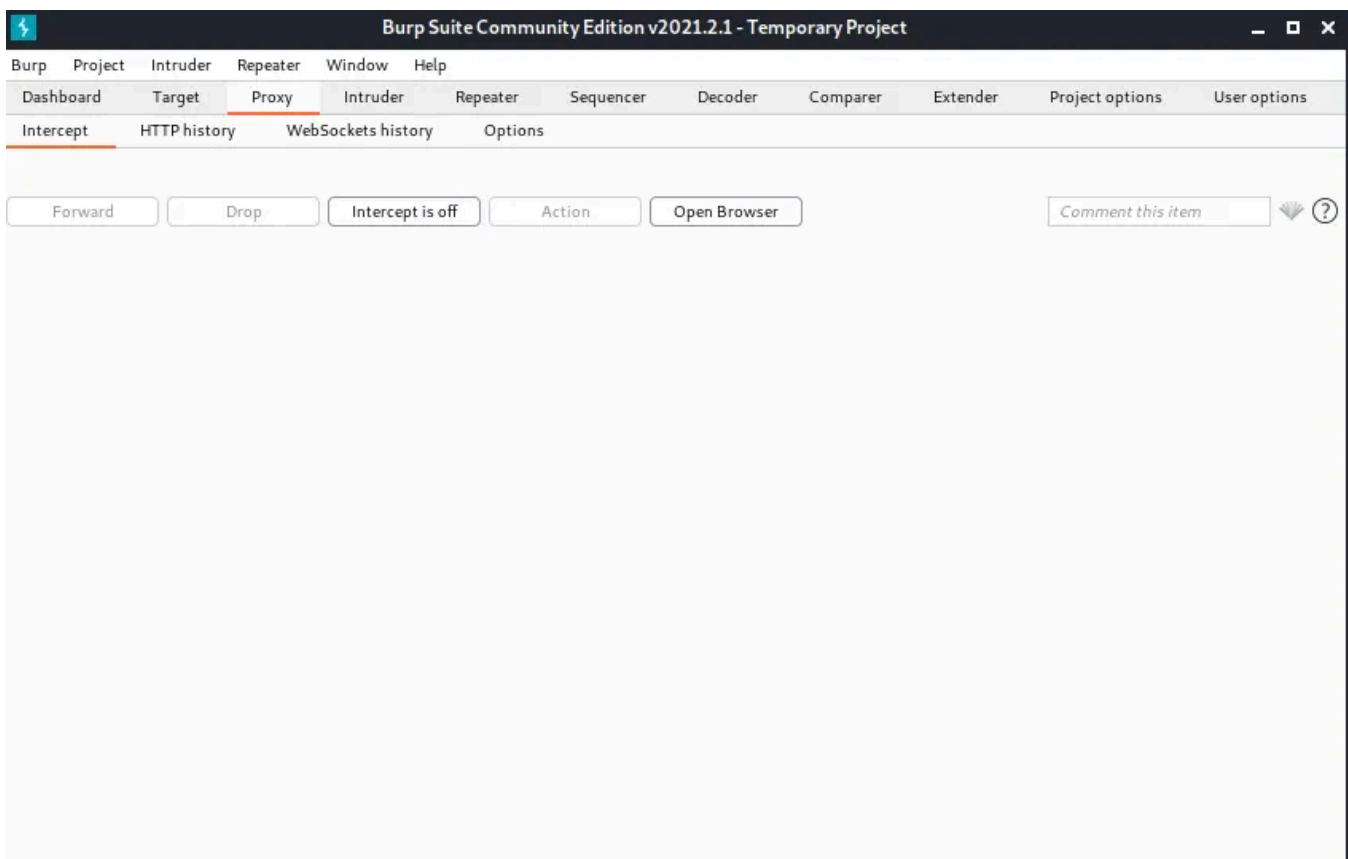
There are multiple ways to start the OWASP Juice Shop including local instances on Docker, or Heroku instances. For conveniences, you can visit <https://juice-shop.herokuapp.com/>.



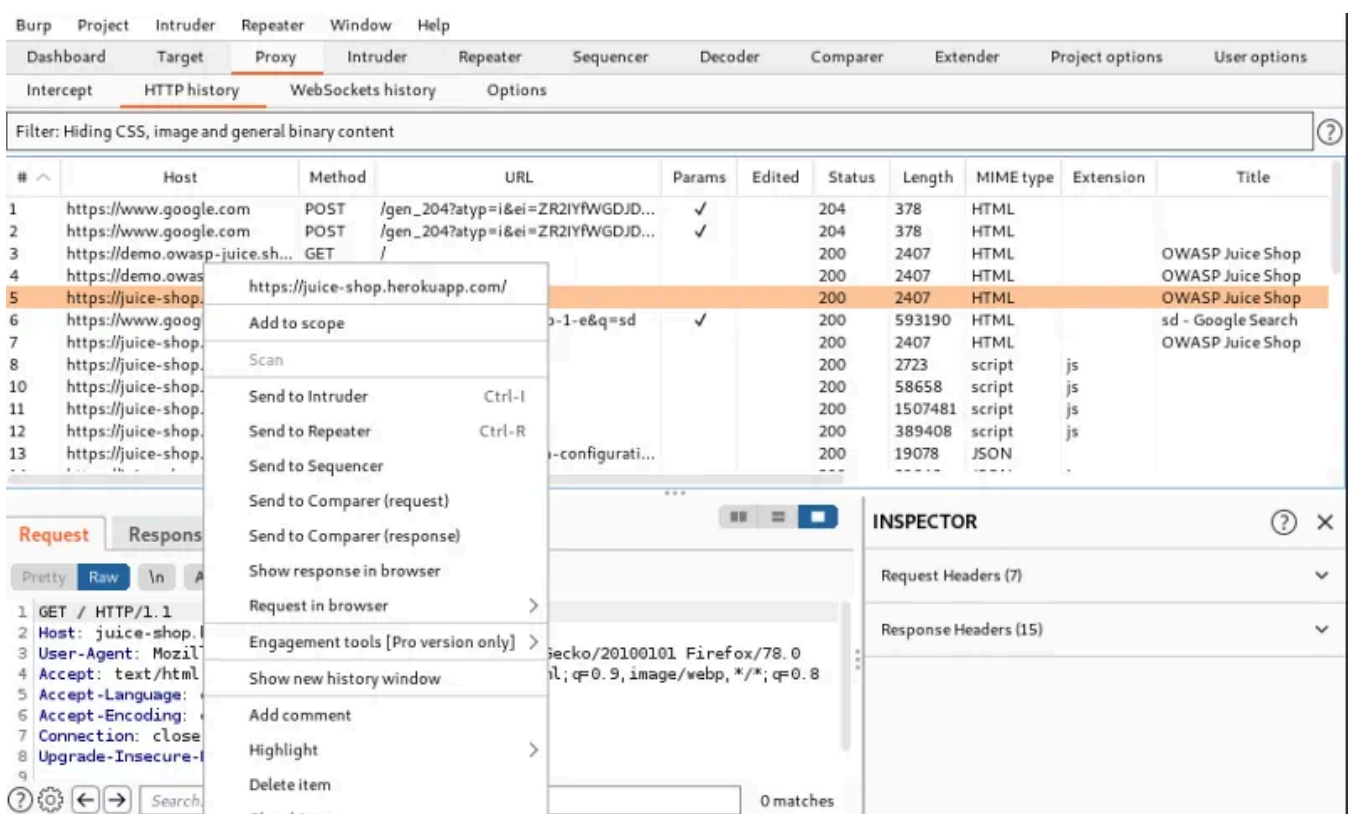
After visiting this website, the page will appear as if it is loading constantly. Do not fear — this is because the Burp Suite proxy server is intercepting all traffic.

Target

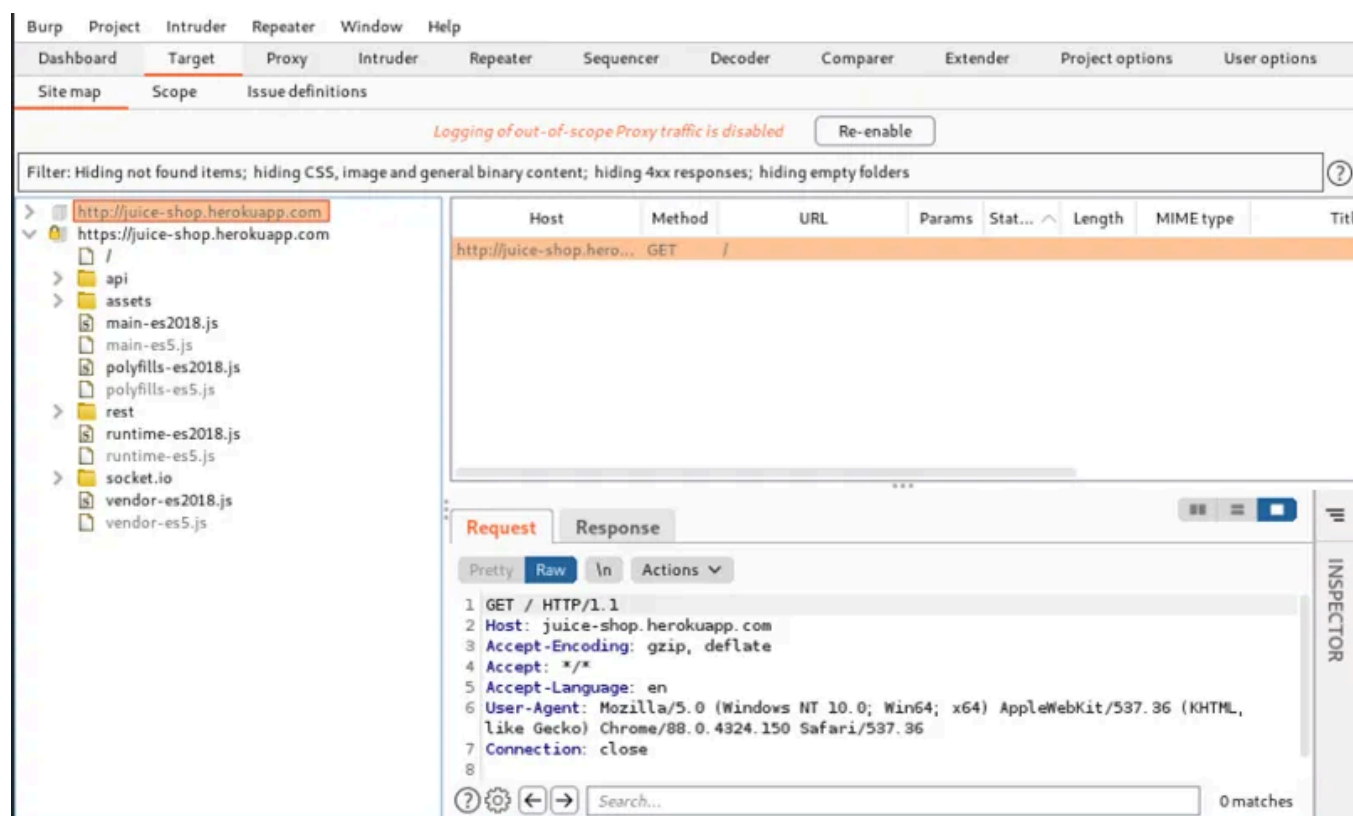
In the Intercept sub-tab under proxy in Burp Suite, turn off intercept.



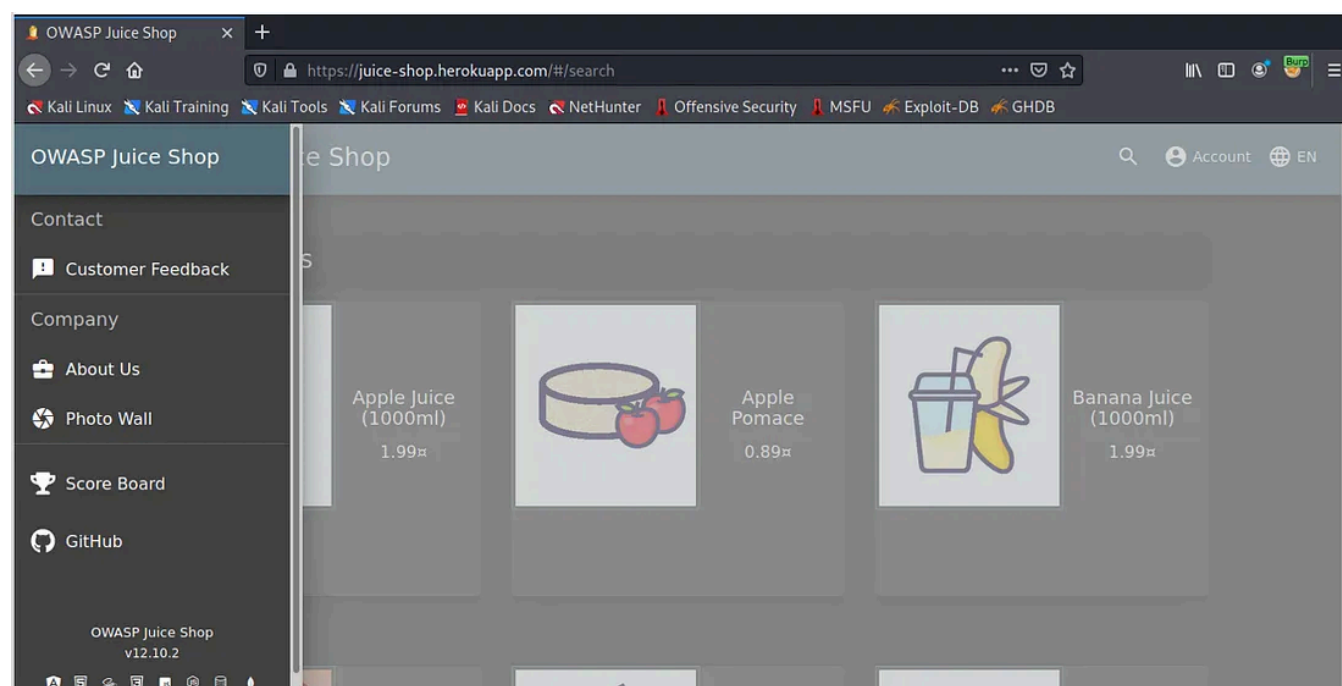
Next, in HTTP history, click on the website and 'add to scope.'



Now explore the website on your browser and go to the target tab. After exploring the web app, you should see the site map of the website.



On the main webpage, clicking on the 3 dashes on the left should show you the Customer Feedback option. Click on this.



Next, give some anonymous feedback, as below.

Customer Feedback

Author: anonymous

Comment: Apple

Max. 160 characters 5/160

Rating: 5/5

CAPTCHA: What is 3+10*7 ?

Result: 73

Submit

When you visit the Proxy http history on Burp Suite, you should see the post request corresponding to this.

Burp Suite Community Edition v2021.2.1 - Temporary Project

Dashboard Target Proxy Intruder Repeater Sequencer Decoder Comparer Extender Project options User options

Intercept HTTP history WebSockets history Options

Logging of out-of-scope Proxy traffic is disabled

Filter: Hiding CSS, image and general binary content

#	Host	Method	URL	Params	Edited
95	https://juice-shop.herokuapp.com	GET	/rest/products/1/reviews		
96	https://juice-shop.herokuapp.com	GET	/rest/products/1/reviews		
97	https://juice-shop.herokuapp.com	GET	/rest/products/1/reviews		
98	https://juice-shop.herokuapp.com	GET	/rest/user/whoami		
99	https://juice-shop.herokuapp.com	GET	/rest/captcha/		
100	https://juice-shop.herokuapp.com	POST	/api/Feedbacks/		✓
101	https://juice-shop.herokuapp.com	GET	/rest/user/whoami		
102	https://juice-shop.herokuapp.com	GET	/rest/captcha/		
103	https://juice-shop.herokuapp.com	GET	/api/Quantities/		
104	https://juice-shop.herokuapp.com	GET	/rest/products/search?q=		✓
105	https://juice-shop.herokuapp.com	GET	/rest/user/whoami		
106	https://juice-shop.herokuapp.com	GET	/rest/products/1/reviews		
107	https://juice-shop.herokuapp.com	GET	/rest/products/1/reviews		

Request Response

Pretty Raw \n Actions

```

13 {
14   "captchaId": 0,
15   "captcha": "73",
16   "comment": "Apple (anonymous)",
17   "rating": 5
18 }
  
```

0 match

Context menu options:

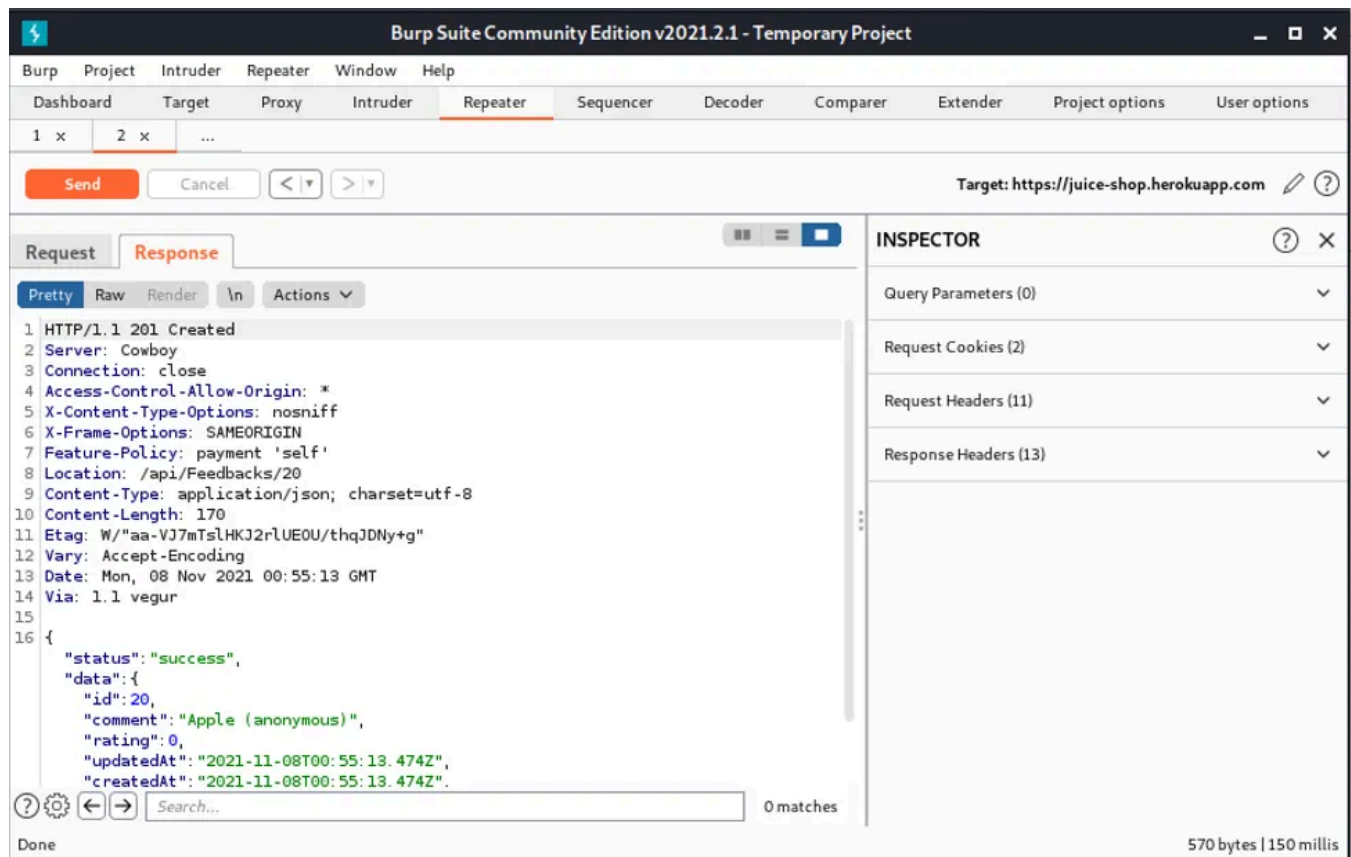
- https://juice-shop.herokuapp.com/api/Feedbacks/
- Remove from scope
- Scan
- Send to Intruder (Ctrl-I)
- Send to Repeater (Ctrl-R)
- Send to Sequencer
- Send to Comparer (request)
- Send to Comparer (response)
- Show response in browser
- Request in browser
- Engagement tools [Pro version only]
- Show new history window
- Add comment
- Highlight
- Delete item
- Clear history
- Copy URL
- Copy as curl command
- Copy links

Repeater

Now, let's try and modify the customer feedback to give an impossibly low rating of 0 out of 5!

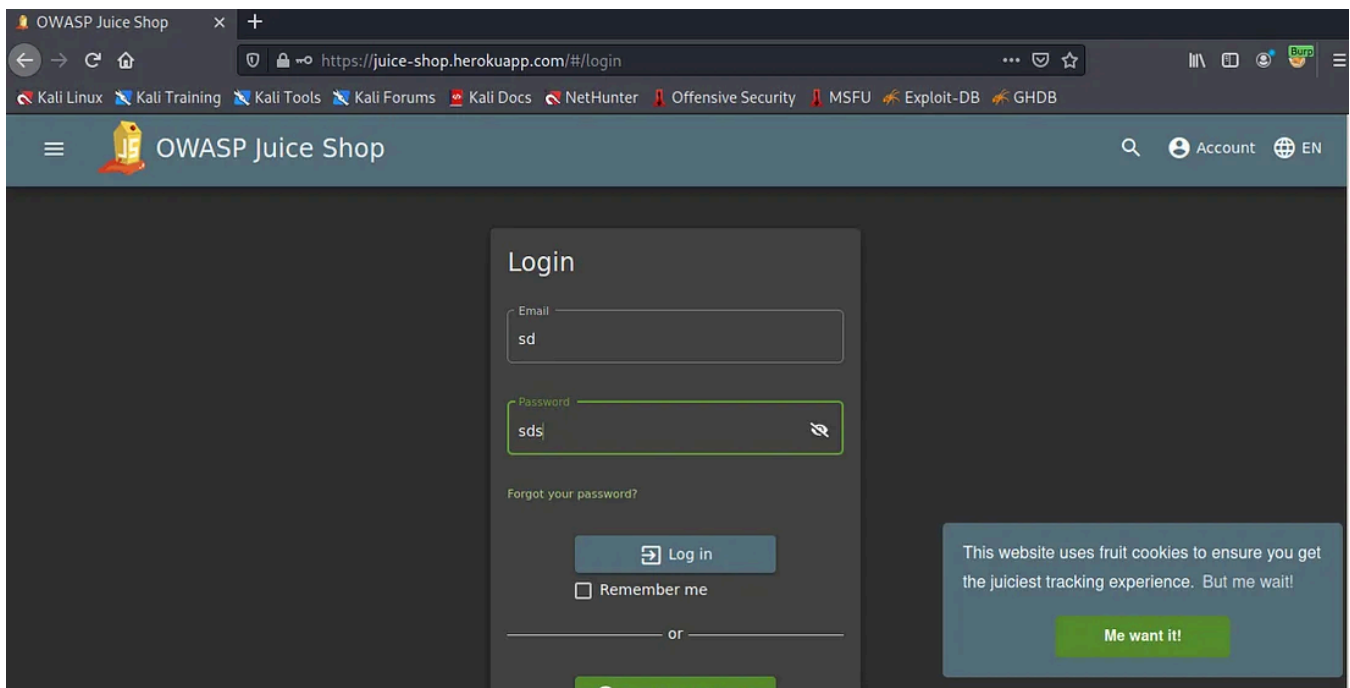
Send this POST request to the repeater, and change the rating value to 0. If the response is a success, then you have successfully sent an extremely low feedback.

I was looking forward to some good, simple, freshly squeezed juice(s) :(.

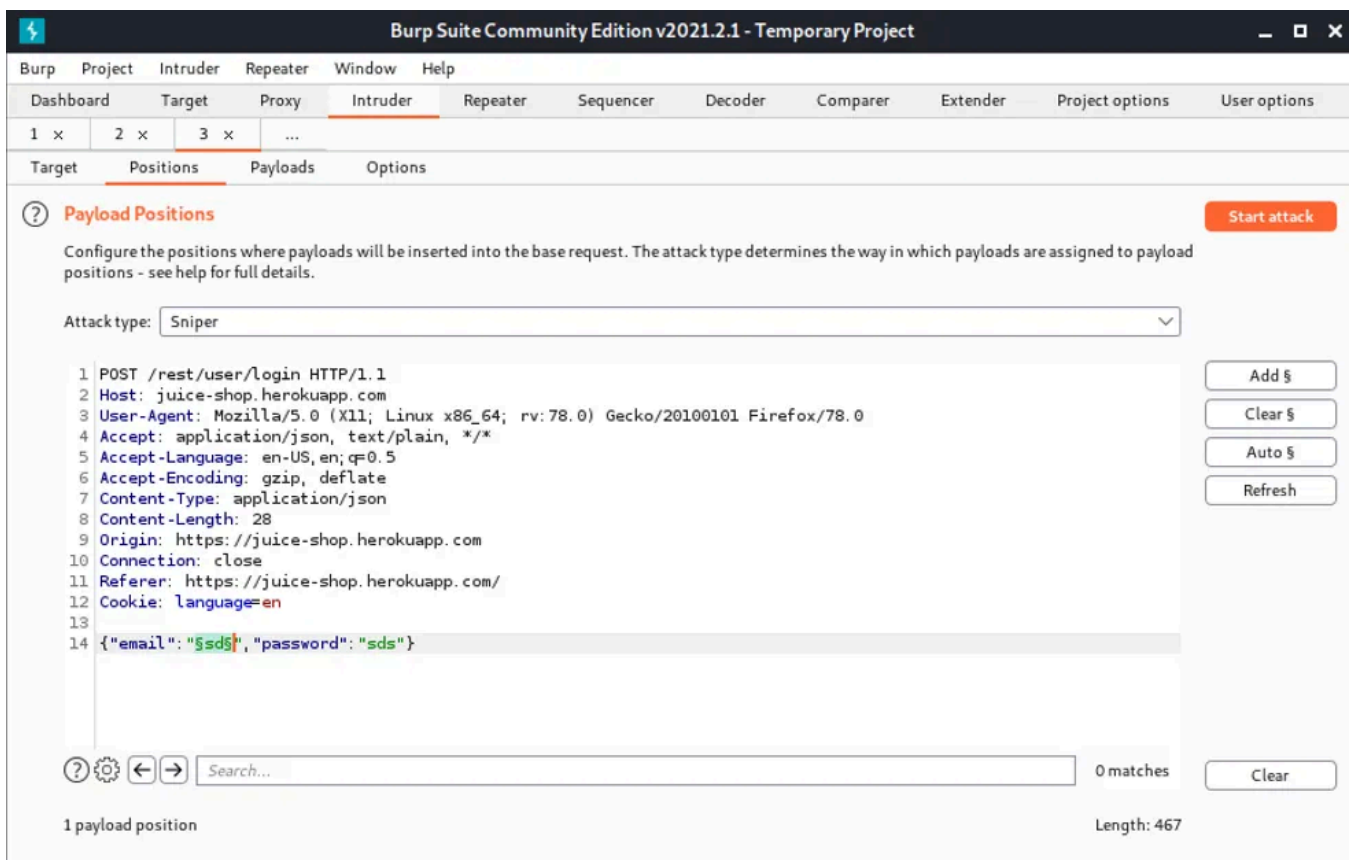


Intruder

In this section, we are going to try and login as admin. You can find the login button on the top right corner. Choose some random credentials (which will of course not work).



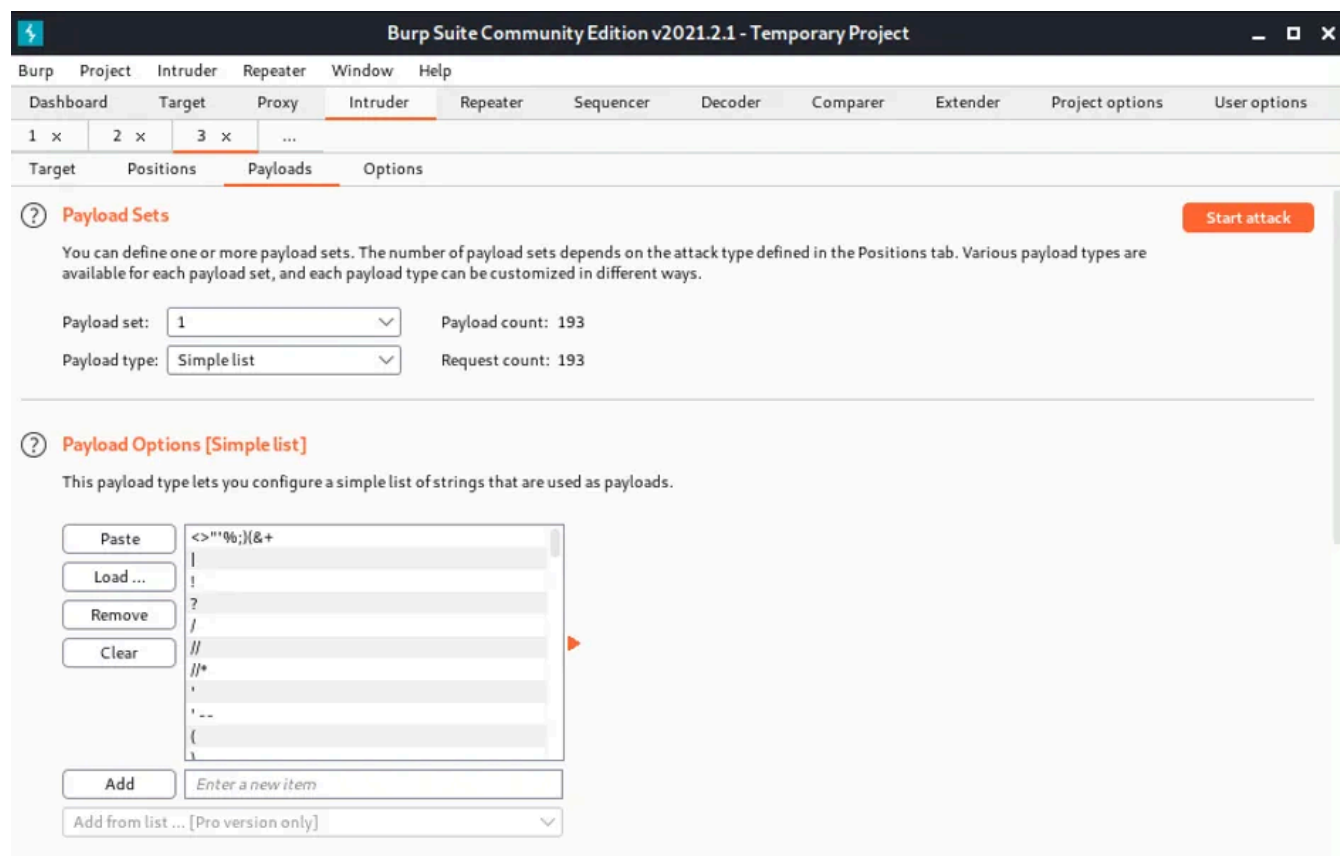
Next, find this post request in the HTTP history, and send to Intruder. Make sure to clear all the highlighted fields, and only choose the email field, and select the *Add \$* button.



Next, we are going to try SQL injection to force our way into the authentication system. SQL injection takes advantage of the syntax of SQL to inject commands. For example in the case of authentication — SQL queries check usernames and

passwords against the list of authenticated users. SQL injection codes could bypass passwords requirements through SQL logic statements. Some standard attacks for default applications are given in this text file: <https://github.com/fuzzdb-project/fuzzdb/blob/master/attack/sql-injection/detect/xplatform.txt>.

In this example, I copy and paste the .txt document into the Intruder Payload sub-tab, and start the attack.



And success! The attack returns a successful 200 status. The resulting SQL injection code is "a' OR 1=1- -".

The screenshot shows the 'Intruder attack1' window in Burp Suite. The top section displays a table of requests with columns: Request, Payload, Status, Error, Timeout, Length, and Comment. Request 51 is highlighted in orange.

Request	Payload	Status	Error	Timeout	Length	Comment
44	%7C	401			394	
45	a'	500			1476	
46	admin' or '	401			394	
47	' and 1=(if{(load_file(char(110...	500			1608	
48	' and 1 in (select var from tem...	500			1501	
49	anything' OR 'x'='x	401			394	
50	"a"" or 1=1--"	500			1404	
51	a' or 1=1--	200			1201	
52	"a"" or 3=3--"	500			1404	
53	a' or 3=3--	200			1201	
54	a' or 'a' = 'a	401			394	
55	'%20OR	401			394	
56	as	401			394	

The bottom section shows the 'Request' tab for request 51, displaying the raw request details:

```

6 Accept-Encoding: gzip, deflate
7 Content-Type: application/json
8 Content-Length: 40
9 Origin: https://juice-shop.herokuapp.com
10 Connection: close
11 Referer: https://juice-shop.herokuapp.com/
12 Cookie: language=en
13
14 {
  "email": "a' or 1=1--",
  "password": "sds"
}

```

At the bottom, there is a search bar and a progress indicator showing '117 of 193'.

When I run this, I get the following confirmation!

The screenshot shows the 'All Products' page in the OWASP Juice Shop. A green banner at the top indicates a successful challenge completion: 'You successfully solved a challenge: Login Admin (Log in with the administrator's user account.)'. Below the banner, three product cards are displayed:

- Apple Juice (1000ml)**: Price 1.99. Includes an 'Add to Basket' button.
- Apple Pomace**: Price 0.89. Includes an 'Add to Basket' button.
- Banana Juice (1000ml)**: Price 1.99. Includes an 'Add to Basket' button.

Each product card features an illustration of the product and a 'Click for more information' link.

Conclusion

I've shown how open access tools Burp Suite and OWASP Juice Shop can be great for learning about and securing web apps. We solved 2 challenges in the OWASP Juice Shop — giving an impossibly low rating, and logging in with the administrator's

account. In doing so, we walked through 4 essential features of securing web apps through Burp Suite: *Proxy, Target, Repeater, and Intruder*. I hope this was useful.

This post was inspired from TryHackMe and specifically this room:

<https://tryhackme.com/room/rpburpsuite>.

If you enjoyed this week's post, please share or tell someone that might enjoy holistic perspectives on the interconnections between technology and modern societies. Feel free to also post any comments in the post discussions on the [cyber-physical substack page](#). This is a small, but growing effort and I hope that you will join me in discovering and building resilient societies.

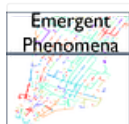
Cybersecurity

Burpsuite

Owasp

Hacking

Web



Follow

Published in Emergent Phenomena

124 followers · Last published Feb 22, 2023

A medium publication for discovering and sharing secrets of our complex everyday world



Follow



Written by Skanda Vivek

3.5K followers · 503 following

Senior Data Scientist in NLP and advisor

Responses (1)



Write a response

What are your thoughts?



Katjah Smith

Feb 14, 2022



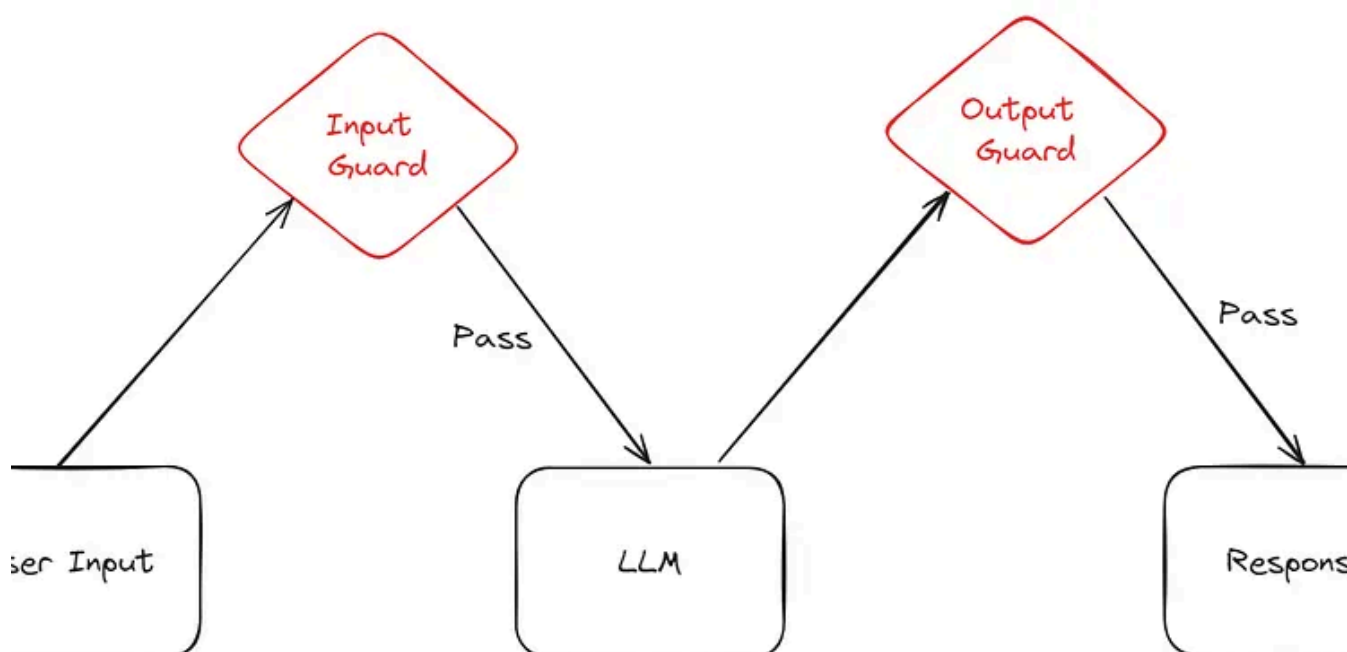
I enjoyed reading this from a different perspective. This was easy to read follow and understand for a beginner like myself



1 reply

[Reply](#)

More from Skanda Vivek and Emergent Phenomena

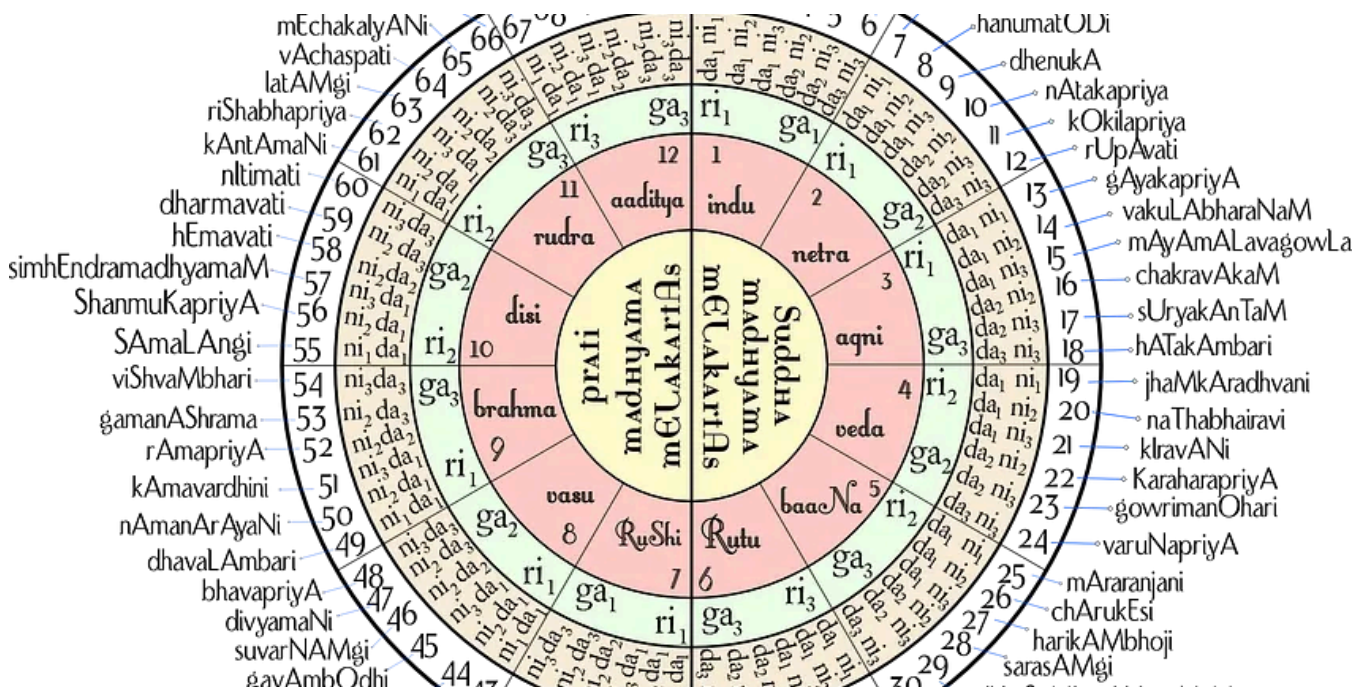


In EMLpha by Skanda Vivek

Safeguarding LLM Conversations Using Llama Guard

Llama Guard recently introduced by Meta aims to safeguard Human-AI conversations — let's see how well it does

Feb 17, 2024 🖱 116 💬 2



In Emergent Phenomena by Skanda Vivek

The Mathematics Behind Indian and Western Music

South Indian Music has 72 complete scales, whereas Western music has 12 major scales. Let's go deeper into the mathematical combinations...



Dec 31, 2020 🖱 104 💬 2





In Emergent Phenomena by Skanda Vivek

The science behind making huge soap bubbles

Now that everyone is at home and it is the summer holiday season, making giant soap bubbles are a great way to have fun and learn science...

Jul 21, 2020 78 2

Methodology	Tools	Pros	Cons
Extracting Text from Documents	PyMUPDF, PyPDF , PDFMiner	Relatively mature, low latency	Does not capture complex structure well, e.g. tables, images, layouts
Converting images to text and extracting text using	Tesseract, Texttract	Relatively mature, captures document structure and able to extract text from images	High latency, use case dependent
Intelligent document parsing	LlamaParse, Unstructured.io, docsumo, Azure Doc Intelligence	Able to capture complex document structure, conversion to markdown	Less mature, lack scalability currently high latency



In EMAlpha by Skanda Vivek

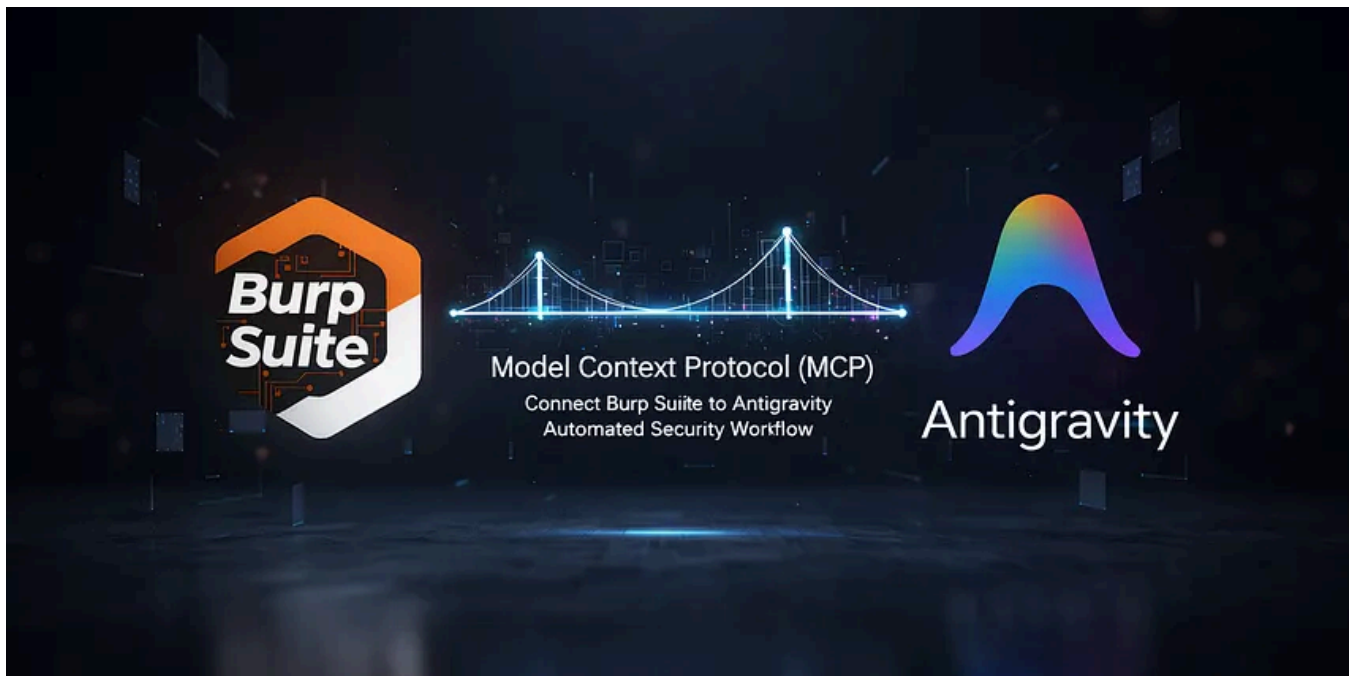
RAG Document Parsers

How Do You Choose A Document Parser For Your RAG Application?

Jul 21, 2024 201

- See all from Skanda Vivek
- See all from Emergent Phenomena

Recommended from Medium

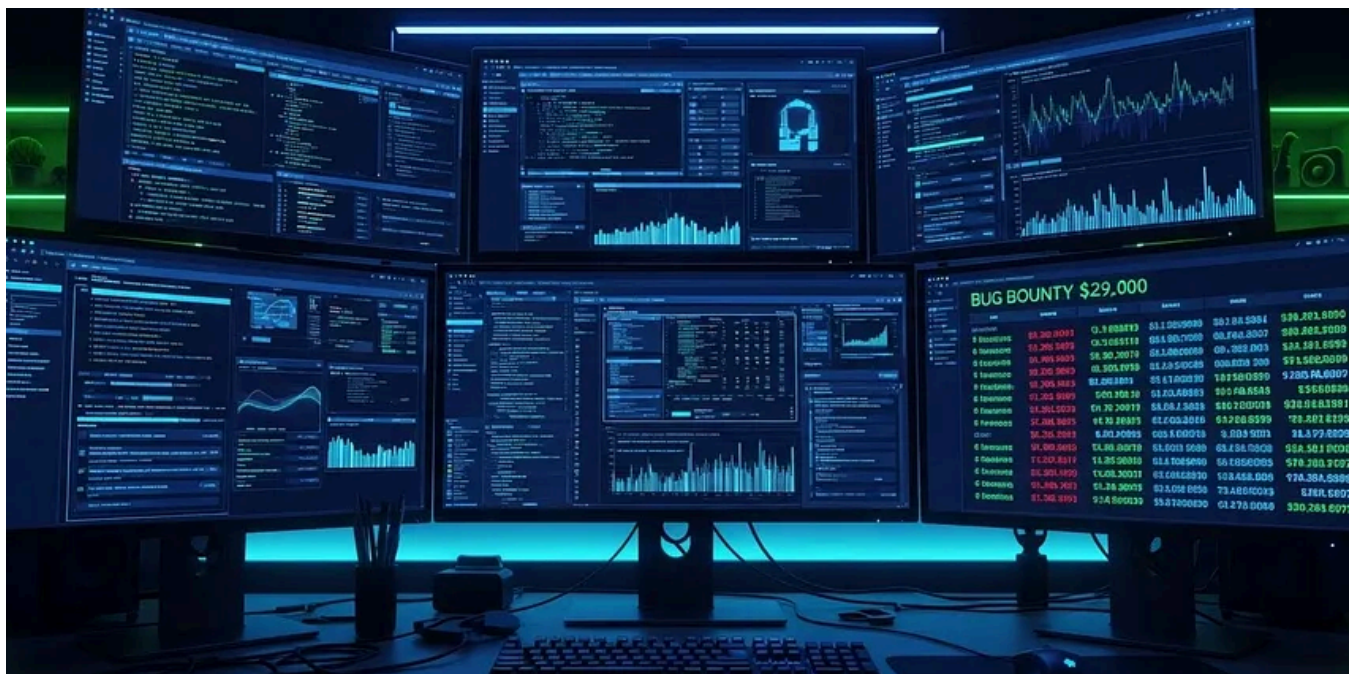


 Jagadishtripathy

Integrating Burp Suite with MCP Using Antigravity

Turn Burp Suite into an AI-callable security toolkit by integrating it with Antigravity through Model Context Protocol (MCP) and accelerate...

Feb 2  242  3



 In System Weakness by BugHunter's Journal

The Bug Bounty Automation Stack That Can Generate \$10K+ (Open Source Tools Only)

Automation doesn't find bugs. Automated workflows combined with manual validation do. While beginners waste time running Nuclei on random...

★ Dec 17, 2025 🖱 465 💬 4

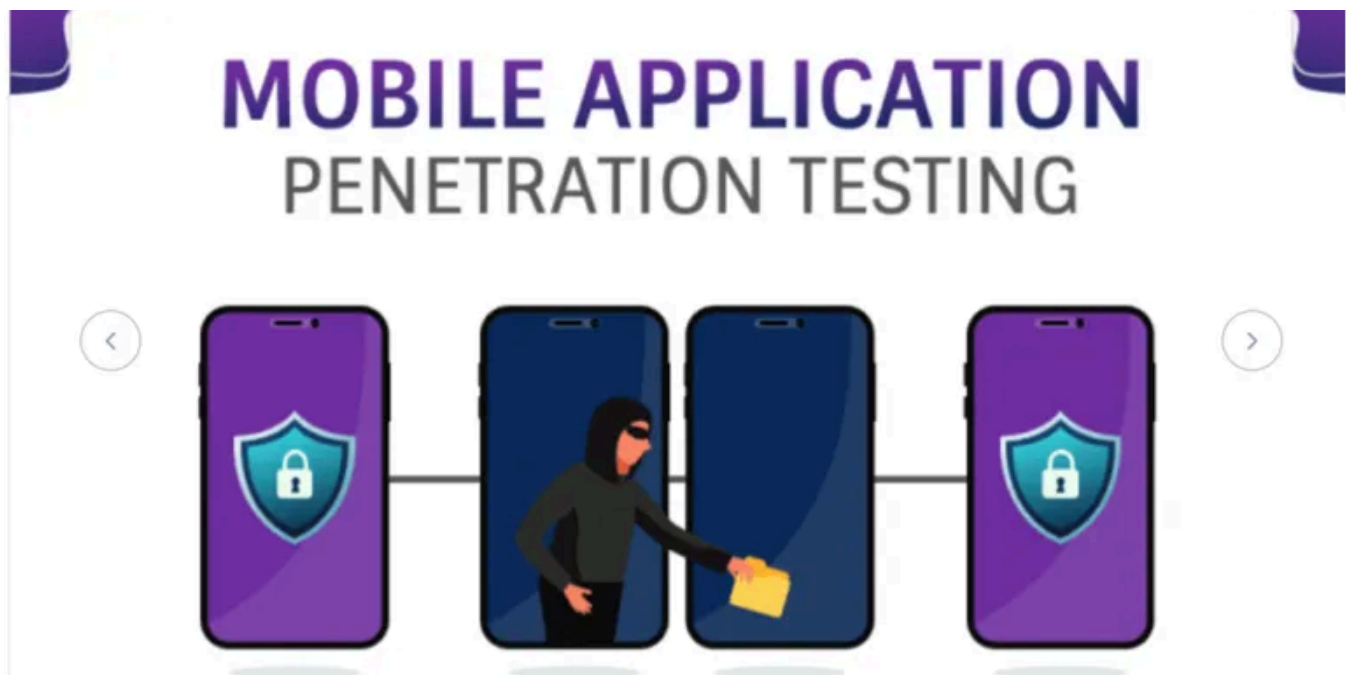


 Ohmkumar

Flutter SSL Pinning: How I Found a New Bypass Technique

 About Me

Feb 14 🖱 37

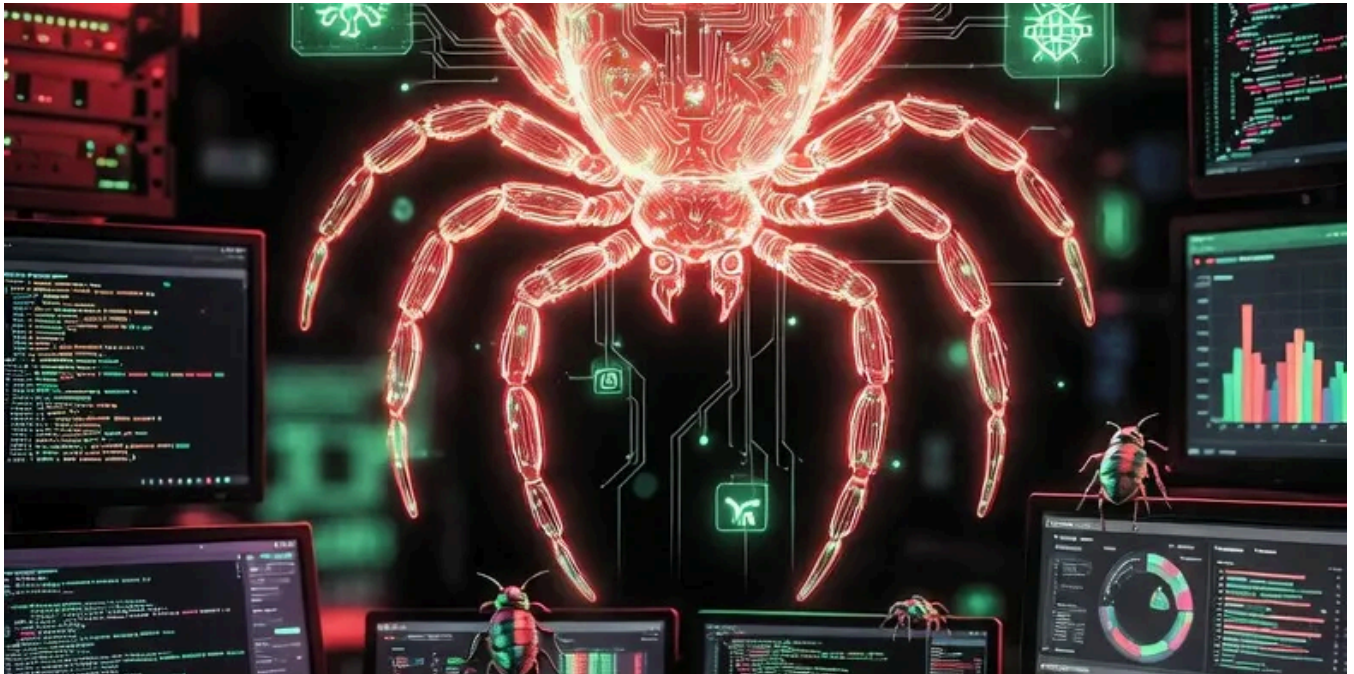


 In T3CH by Nol White Hat

Mobile pen testing part 1: Set a mobile pentest environment with Objection, Frida and Burp on Kali...

Summary (updated 11-01-2026)

Dec 3, 2025 🖱 66 💬 2



In Bug Bounty Hunting: A Comprehensive Guide in English and french by ghostyjoe



Top 10 Burp Suite Extensions for Bug Bounty Hunters



Supercharge Your Burp Suite Workflow



Mar 16 🖱 6





In InfoSec Write-ups by Xcheater

All About Android Pentesting

Complete Android application security testing guide: Static & dynamic testing, root detection bypass, SSL pinning, and common vuln...

Nov 23, 2025



356



10



See more recommendations